Microsoft Security

Secure Copilot Studio Agents with Microsoft Entra Global Secure Access

Michael Michalos
Sr. Cloud Solution Architect – Europe South Tech Lead, Threat Protection

Disclaimer: This presentation reflects my personal views and experience. It is not an official Microsoft presentation or statement.



About me: Michael Michalos

Role

Sr. CSA – Threat Protection | Europe South Tech Lead

Former Microsoft Security MVP

Experience and background

Over 15 years of experience in ICT

Working in Cybersecurity since 2019

Electrical Engineer BSc, MSc, MBA

Father of 2, lifetime Scout, own a wine cooler, and a watch enthusiast

Projects

Blogging at michalos.net

github.com/cyb3rmik3/KQL-threat-hunting-queries

github.com/cyb3rmik3/MDE-DFIR-Resources

github.com/christosgalano/sKaleQL

Featured in: KQL Search, Kusto Insights, The Definitive Guide to KQL

Before we begin, what are Copilot Studio agents and Global Secure Access?

Copilot Studio agents

- Low-code AI agents built in Microsoft Copilot Studio
- Act autonomously on behalf of users and the business
- Reach external services through connectors, HTTP nodes and MCP tools

Microsoft Copilot Studio | Create AI Agents

Global Secure Access (GSA)

- Microsoft's Security Service Edge (SSE), part of Microsoft Entra
- Routes traffic through a cloud proxy that enforces web filtering, threat intelligence, content and prompt policies
- Logs traffic for visibility and investigation

What is Global Secure Access? - Global Secure Access | Microsoft Learn

Why this matters now

Agent egress paths

Connectors, HTTP nodes, and MCP tools

Existing controls can be bypassed

Traffic can bypass existing user SSE controls

Emerging threats

Exfiltration, shadow MCP usage, and adversarial prompts

Agent egress threat model

Data exfiltration

- Data can leave through unsanctioned AI destinations

Unmanaged destinations

- Unmanaged outbound destinations for autonomous actions

Prompt injection

- Prompt injection and jailbreak attempts against enterprise workflows

Limited visibility

- Limited visibility without protocol- and content-aware inspection

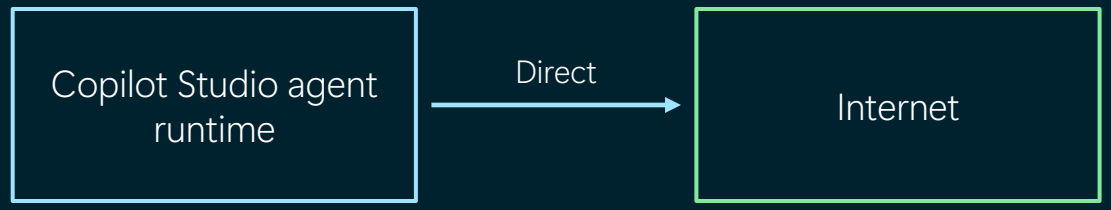
Architecture: before vs after GSA

Before GSA

- Copilot Studio agent runtime connects to the internet directly

After GSA

- Agent runtime traffic flows through GSA to the destination
- Enforcement: web filtering, threat intel, content policy, prompt policy
- Observability: traffic logs and Gen AI Insights (MCP telemetry)





Enforcement model (critical distinction)

User traffic

Security profile can be attached via Conditional Access

Agent traffic

No interactive user session context

Agent enforcement anchor

Baseline profile linkage

Routing prerequisite: enable Global Secure Access for Agents in PPAC

Prerequisites

GSA Administrator

- Microsoft Entra ID role
- Manages GSA features and policies

Power Platform Administrator

- Manages Copilot Studio environments
- Enables GSA for Agents in the Power Platform admin center

Power Platform environment

- Dataverse added to the environment
- Hosts the agents whose traffic GSA secures

Licenses

- Entra ID P1 or P2
- Entra Internet Access (standalone or in Entra Suite)
- Microsoft Agent 365
- Even better, E7 ☺

Deployment prerequisites and gotchas

Enable and connect

- Enable GSA for Agents per Power Platform environment
- Re-save pre-existing custom connectors after enabling integration

Roll out safely

- Use a pilot environment first, then scale by policy maturity
- Prepare deterministic test cases before policy hardening

Demo walkthrough

Five demos from enablement to validation

Demo 1: Enable GSA for Copilot Studio Agents

Navigate

- PPAC → Security → Identity & access → Global Secure Access for Agents

Steps

- Select target environment
- Run Set up
- Enable toggle and Save

Expected result

- Environment state reflects active GSA integration

Demo 2: Create web content filtering policy

Navigate

Entra → GSA → Secure → Web content filtering policies

Steps

Create block policy for high-risk categories

Example categories: Hacking, Illegal Software, Web Repository and Storage

Expected result

Policy created and ready for profile linkage

Demo 3: Apply policy to Baseline profile

Navigate

GSA → Secure → Security profiles → Baseline profile

Steps

Edit profile

Link policies → Existing Web Content Filtering Policy

Attach policy and save

Expected result

Policy visible under linked baseline controls

Demo 4: Prompt injection protection policy

Create the policy

- GSA → Secure → Prompt policies → Create policy

Configure the rule

- Add block rule for adversarial prompt patterns
- Conversation schemes: ChatGPT, Claude, Gemini, or Custom

Link and verify

- Link policy to profile; verify active policy chain

Demo 5: Threat intelligence & content policies

Navigate

Threat intelligence: Entra → GSA → Secure → Threat intelligence policies

Web content: Entra → GSA → Secure → Web content filtering policies

Steps

Threat intelligence: Create policy to block known malicious destinations (phishing, malware, C2)

Web content: Create block policy for Hacking, Illegal Software, Web Repository and Storage

Expected result

Both policies created and ready to link to a security profile

One threat intelligence policy per profile

Demo 6: Validate enforcement and visibility

Navigate

GSA → Monitor → Traffic logs (transactions/connections)

Steps

Correlate policy decision with test action and destination

Review Gen AI Insights/MCP telemetry where available

Expected result

Proof of detection and enforcement in logs

What GSA does not inspect (boundaries)

Inspection limit

- Agent traffic is encrypted, like any HTTPS site
- Without TLS inspection, GSA sees only the destination, not the content
- GSA can block a site, but can't filter what the agent sends to it

Routing limit

- GSA controls only traffic that is routed through it
- Bing search and unsupported connectors bypass GSA
- Traffic that bypasses GSA is neither logged nor blocked

Legacy connectors

- Connectors built before GSA was enabled keep their old routing
- Open and re-save each one so its traffic goes through GSA
- Connectors created afterwards are covered automatically

Continuous validation

- Turning GSA on doesn't prove it is working
- Review traffic logs to confirm agent traffic appears and blocks fire
- Re-test after adding agents, connectors or policies

Production baseline and operating model

Start restrictive

Start with restrictive categories + destination controls

Expand coverage

Expand prompt policy coverage by approved model/provider endpoints

Govern and measure

Implement exception workflow and change governance

Track KPIs: blocked attempts, risky destinations, override frequency

Q&A

Thank you!

Don’t forget to connect!

https://www.michalos.net/
https://github.com/cyb3rmik3
https://www.linkedin.com/in/mmihalos/